SISTEMAS WEB
CURSO 2025/2026

APIs Web
Delegación de autenticación y autorización: OAuth

Web Sistemak by Oskar Casquero & María Luz Álvarez is licensed
under a Creative Commons Reconocimiento 4.0 Internacional License.

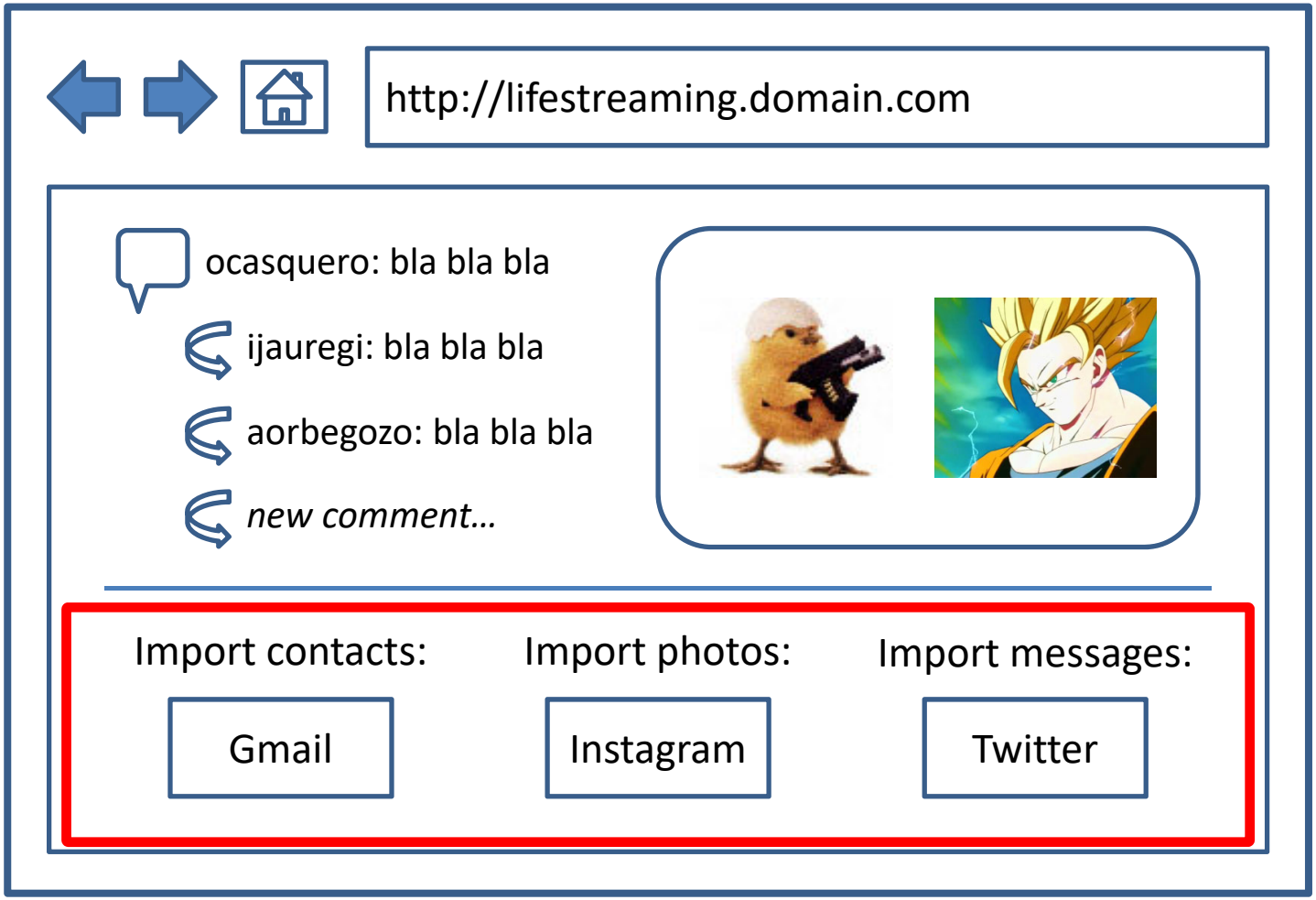
Oskar Casquero y María Luz Álvarez
Dpto. Ingeniería de Sistemas y Automática

DELEGACIÓN DE AUTENTICACIÓN Y AUTORIZACIÓN SUPONGAMOS…

- que estamos desarrollando una aplicación.
- Los usuarios de nuestra aplicación, además, son usuarios de otras aplicaciones web como *Google Calendar*, *Google Drive*, *Dropbox*, *Twitter*, *Instagram*,…

- **Objetivo** de nuestra aplicación es que los usuarios de esta aplicación puedan utilizar los datos que tienen en las otras aplicaciones:
  - *Google Calendar*: calendarios, citas
  - *Google Drive* y *Dropbox*: ficheros
  - *Twitter*: tuits
  - …

DELEGACIÓN DE AUTENTICACIÓN Y AUTORIZACIÓN
PROBLEMA 1



Oskar Casquero y María Luz Álvarez
Dpto. Ingeniería de Sistemas y Automática

DELEGACIÓN DE AUTENTICACIÓN Y AUTORIZACIÓN
PROBLEMA 1

Oskar Casquero y María Luz Álvarez
Dpto. Ingeniería de Sistemas y Automática

DELEGACIÓN DE AUTENTICACIÓN Y AUTORIZACIÓN PROBLEMA 2

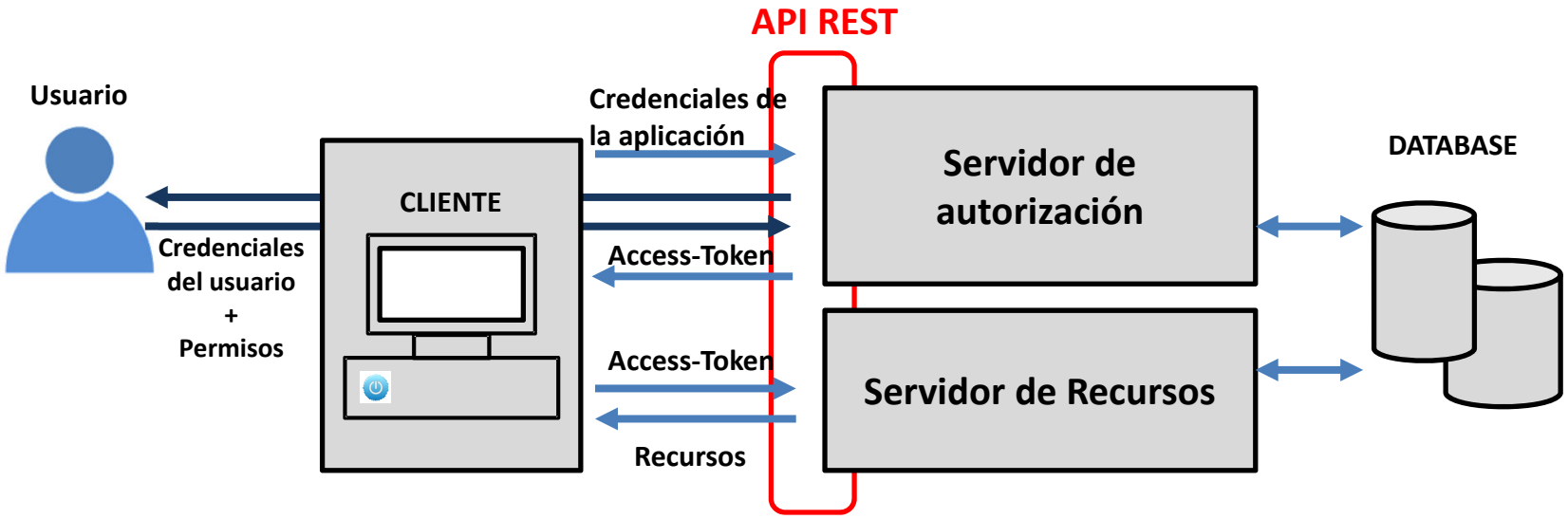
- **Autenticación vs Permiso**
- La cuenta de Google nos da la posibilidad de entrar y utilizar un gran número de servicios: contactos, mail, calendarios, documentos, …
- Una vez autenticada la aplicación del ejemplo anterior *lifestreaming.domain.com*
  - ¿En que servicios puede entrar la aplicación?
    - contactos
  - ¿Que puede hacer en este servicio?
    - Leer contactos pero no puede generar nuevos contactos ni borrar los contactos.

SOLUCIÓN: OAUTH

Llave *Valet*: Esta llave especial sólo permite conducir el coche una corta distancia, bloquea el acceso al maletero o al teléfono móvil de a bordo. La idea es **darle a alguien el acceso limitado a el coche.**
Credenciales. Pero, la llave no se la das a cualquiera, en un restaurante se la das al aparcacoches si acredita que trabaja en el restaurante

- El protocolo *OAuth* permite a un usuario de una web A acceder a los datos que este usuario tiene en una web B.
- En este proceso, se utiliza un mecanismo indirecto para que la web A no vea el nombre de usuario y contraseña de la web B.

SOLUCIÓN: OAUTH



El flujo típico de *OAuth* implica varios actores:

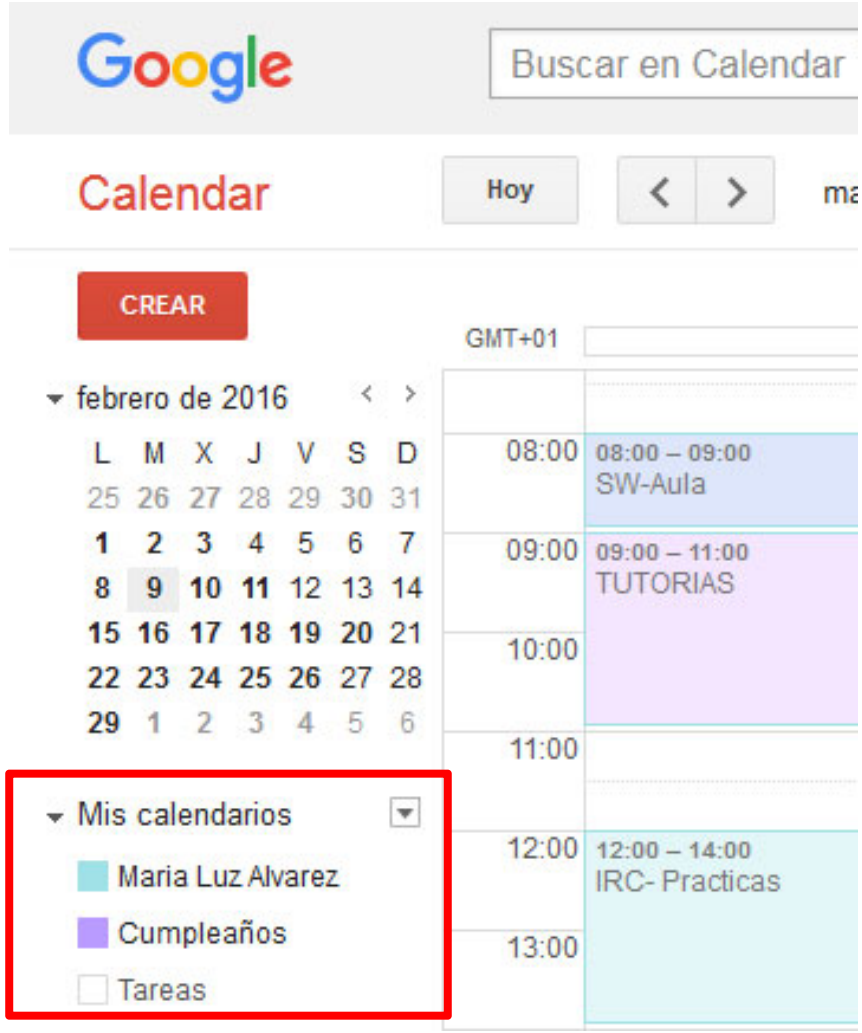
- **Usuario** propietario del recurso: El individuo que posee los datos que se están compartiendo. Por ejemplo, un usuario de una red social o de un servicio de correo electrónico.
- **Cliente:** La aplicación de terceros que solicita acceso a los recursos del propietario del recurso. Por ejemplo, una aplicación móvil o un sitio web
- **Servidor de autorización**: El servidor responsable de autenticar al propietario del recurso y emitir tokens de acceso al cliente después de la autorización exitosa.
- **Servidor de recursos**: El servidor que almacena los recursos protegidos, como los datos del usuario.

VERSIONES OAUTH : 2.0 Y 1.0

- OAuth 2.0: RFC 6749
  - Usuarios: Google, Amazon,
    Dropbox, GitHub,
    Facebook, Instagram,
    Strava, LinkedIn, …
- OAuth 1.0: RFC 5849
  - Usuarios: Twitter, Flickr, …

- Diferencia principal entre las dos versiones:
  - En OAuth 1.0 la petición HTTP va firmada

- Sitio web oficial: http://oauth.net

EJEMPLO: CALENDARIO DE GOOGLE

- Programamos un cliente Python.
- Este cliente conseguirá la lista calendarios Google de un usuario utilizando OAuth for mobile & desktop apps.